PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Menaces de l'IA générative en 2025

03-780 ANSSI - L'IA générative face aux attaques informatiques, synthèse de la menace 2025 — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. L'ANSSI ne recense aucune cyberattaque contre des acteurs français ni d'IA capable d'une attaque entièrement autonome.
2. Les attaquants utilisent l'IA pour l'ingénierie sociale, la création de codes malveillants ou l'analyse massive de données exfiltrées.
3. Les menaces sur les systèmes d'IA se structurent autour de trois niveaux : l'entraînement, l'intégration et l'inférence.

Cadre de la synthèse

Notion	À retenir
Le périmètre	Synthèse du **CERT-FR** (**04/02/2026**) sur les **IA génératives** (**LLM**). Complétée par le guide **ANSSI** du **29/04/2024**.
Le constat principal	**Aucune** cyberattaque contre des acteurs français connue, ni d'IA capable de réaliser **seule** toutes les étapes d'une attaque.

Synthèse de l'IA au service des attaquants

Notion	À retenir
Ingénierie sociale	Reconnaissance d'experts via **Gemini** (Iran) ; hameçonnage (**Charcoal Typhoon**, Chine) ; faux profils réseaux sociaux (**Lazarus**, Corée du Nord) ; sites légitimes générés par IA ; deepfakes.
Codes malveillants	Script `PowerShell` généré par LLM (**TA547**, 2024) ; **PromptLock** (prototype universitaire de rançongiciel piloté par prompts) ; **Promptflux** (code polymorphique réécrit via l'API **Gemini** toutes les heures).
Analyse de données	Opérateurs russes utilisant l'IA pour analyser massivement les données exfiltrées et repérer les informations d'intérêt (**février 2025**).
Limites actuelles	Dépendance aux compétences humaines ; sur une **cinquantaine** d'IA testées, **3** seulement ont produit un **exploit fonctionnel** (après de nombreuses heures) ; aucun cas avéré d'exploitation d'un **jour-zéro** découvert par IA.

Profils et usages des attaquants

Notion	À retenir
Large spectre d'acteurs	Gemini utilisé (2023-2024, selon Google en janvier 2025) par des cybercriminels et au moins : **Iran** (10), **Chine** (20), **Corée du Nord** (9), **Russie** (3) modes opératoires.
Acteurs matures vs débutants	**Matures** : cadre pratique (**Cobalt Strike**, **Metasploit**), contenu en masse, code non signant, recherche rapide. **Débutants** : apprentissage et productivité. L'IA permet d'agir **plus vite** et à **plus grande échelle**. Évolution possible : automatisation (quasi) complète de la chaîne d'attaque.

Détournement des modèles existants

Notion	À retenir
Le contournement des garde-fous	Utilisation de l'**ingénierie de prompt** (formulations ambiguës, scénarios fictifs). **2023** : code polymorphique. **2024** : services `jailbreak-as-a-service` (**EscapeGPT**, **LoopGPT**).
Les IA débridées	Services vendus sur forums ou **Telegram** pour **une centaine de dollars par mois** dès **2023** (**WormGPT**, **FraudGPT**, **EvilGPT**). **WormGPT 4** : entraîné sur **code malveillant** et **hameçonnage**.

Synthèse des menaces sur les systèmes d'IA

Notion	À retenir
Trois niveaux d'attaque	**Entraînement** (données corrompues), **Intégration** (portes dérobées), **Inférence** (fausses informations ou récupération de données confidentielles).
Empoisonnement et désinformation	**250 documents** malveillants suffisent à empoisonner un modèle. Risque d'altération de données ou **sabotage** de systèmes opérationnels.
Chaîne d'approvisionnement et données	**Slopsquatting** (paquets inventés par hallucination), **agents MCP** mal sécurisés, vol de **> 100 000 comptes ChatGPT** par infostealers (2022-2023), fuite **Samsung** via ChatGPT (2023).

Pièges et confusions

- ⚠ Confondre PromptLock (prototype de rançongiciel universitaire) et Promptflux (code polymorphique)
- ⚠ Confondre les services de jailbreak-as-a-service (EscapeGPT, LoopGPT) et les IA débridées (WormGPT, FraudGPT, EvilGPT)
- ⚠ Croire qu'une IA a déjà exploité une vulnérabilité jour-zéro
- ⚠ Penser qu'une IA peut mener une attaque de manière totalement autonome

Sigles et définitions

IA générative	systèmes qui génèrent des contenus (texte, images, vidéos ou code) à partir de modèles entraînés
GML ou LLM	modèle d'IA spécialisé dans l'analyse et la génération de contenus textuels ou de code
Jailbreak-as-a-service	service cybercriminel vendant des prompts pour contourner les garde-fous des IA
Empoisonnement	introduction de données corrompues ou fausses dans les données d'entraînement d'un modèle
Slopsquatting	enregistrement de noms de paquets logiciels inventés par les hallucinations d'une IA pour diffuser des versions malveillantes
Infostealer	code malveillant qui collecte les identifiants, mots de passe et cookies de session
Requête ou prompt	instruction textuelle envoyée par l'utilisateur au système d'IA

Auto-test

1. Combien de documents malveillants suffiraient pour empoisonner un modèle ?
2. Quels sont les trois niveaux d'attaque d'un LLM ?
3. Combien de modes opératoires liés à la Chine sont mentionnés par Google ?
4. Comment appelle-t-on l'instruction textuelle envoyée par l'utilisateur à l'IA ?
5. Quel est le nom du code polymorphique qui réécrit son code toutes les heures avec Gemini ?

Réponses : **1.** 250 · **2.** l'entraînement, l'intégration et l'inférence · **3.** 20 · **4.** une requête ou prompt · **5.** Promptflux

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.